Security Review

Cantina Managed

SKY: NFAT

Cantina Managed review by:
Christoph Michel, Lead Security Researcher
Xmxanuel, Lead Security Researcher

CANTINA

October 21, 2026

Contents

1 Introduction **2**
- 1.1 About Cantina . . . 2
- 1.2 Disclaimer . . . 2
- 1.3 Risk assessment . . . 2
  - 1.3.1 Severity Classification . . . 2

2 Security Review Summary **3**
- 2.1 Scope . . . 3

3 Findings **4**
- 3.1 Informational . . . 4
  - 3.1.1 Restrict NFAT issuance rights to the associated Halo PAU . . . 4
  - 3.1.2 Minor issues, Typos & Documentation . . . 4

1 Introduction

1.1 About Cantina

Cantina is a security platform that pairs a world-class network of security researchers with agentic AI to help teams building onchain find and fix real risk. Through managed reviews, competitions, and bounties, Cantina secures protocols before vulnerabilities can be exploited.
Learn more at cantina.security

1.2 Disclaimer

Cantina Managed provides a detailed evaluation of the security posture of the code at a particular moment based on the information available at the time of the review. While Cantina Managed endeavors to identify and disclose all potential security issues, it cannot guarantee that every vulnerability will be detected or that the code will be entirely secure against all possible attacks. The assessment is conducted based on the specific commit and version of the code provided. Any subsequent modifications to the code may introduce new vulnerabilities that were absent during the initial review. Therefore, any changes made to the code require a new security review to ensure that the code remains secure. Please be advised that the Cantina Managed security review is not a replacement for continuous security measures such as penetration testing, vulnerability scanning, and regular code reviews.

1.3 Risk assessment

Severity level	Impact: High	Impact: Medium	Impact: Low
Likelihood: high	Critical	High	Medium
Likelihood: medium	High	Medium	Low
Likelihood: low	Medium	Low	Low

1.3.1 Severity Classification

The severity of security issues found during the security review is categorized based on the above table. Critical findings have a high likelihood of being exploited and must be addressed immediately. High findings are almost certain to occur, easy to perform, or not easy but highly incentivized thus must be fixed as soon as possible.

Medium findings are conditionally possible or incentivized but are still relatively likely to occur and should be addressed. Low findings are a rare combination of circumstances to exploit, or offer little to no incentive to exploit but are recommended to be addressed.

Lastly, some findings might represent objective improvements that should be addressed but do not impact the project's overall security (Gas and Informational findings).

2 Security Review Summary

From Oct 5th to Oct 7th the Cantina team conducted a review of nfat on commit hash 05ca58db. The team identified a total of **2** issues:

Issues Found

Severity	Count	Fixed	Acknowledged
Critical Risk	0	0	0
High Risk	0	0	0
Medium Risk	0	0	0
Low Risk	0	0	0
Gas Optimizations	0	0	0
Informational	2	2	0
Total	**2**	**2**	**0**

The Cantina Managed team reviewed Sky's nfat holistically on commit hash fa089fe0 and concluded that all findings were addressed and no new vulnerabilities were identified.

2.1 Scope

The security review had the following components in scope for nfat on commit hash 05ca58db:

```
nfat/deploy/NFATInit.sol
nfat/deploy/NFATDeploy.sol
nfat/script/DeployNFAT.s.sol
```

3 Findings

3.1 Informational

3.1.1 Restrict NFAT issuance rights to the associated Halo PAU

Severity: Informational.

Context: NFATInit.sol#L74.

Description:

The `NFATInit` init library allows adding separate operators on top of the Halo PAU. Allowing multiple operators to call `issue` can break Halo NFAT accounting. Note that all issuances are still sent to the `recipient` Halo ALM proxy, but `HaloNfatFacet` would not track third-party issuances and therefore cannot repay it.

Recommendation:

Clarify the use-case for having multiple, different issuers for the same Halo NFAT recipient. Consider restricting issuance authority to the single Halo ALM proxy associated with the NFAT facility to avoid the accounting / repayment issue.

3.1.2 Minor issues, Typos & Documentation

Severity: Informational.

Context: (see each case below).

Description:

- 1) test/NFATFacility.t.sol#L248: NFATInit validates three config mismatches (gem, name, symbol), but only the gem mismatch has a revert test (testRevertInitGemMismatch). Consider adding tests for all.
- 2) deploy/NFATInit.sol#L46: init can be re-run. With the same params it is a silent no-op, but it cannot cleanly re-initialize the facility for a different ALMProxy, the old proxy stays an operator. Blocking re-init entirely with `require(facility.recipient() == address(0), "NFATInit/recipient-already-set")` at the top of init is cleaner.

Recommendation: Consider addressing the mentioned issues.